



Cybersecurity: Prevention and Intervention (LEA.D8)

420-1C1-DW Preventative Monitoring | Topic 1, Foundations of Cybersecurity (continued)

Common Types of Cyberattacks and Basic Cyber Defense Concepts

Class 3: Lesson 1.3 and Lesson 1.4

Friday, September 18, 2026, online | Instructor: Asen Grozdanov, Cyber.SoHo Educational Hub



Today: two questions, six objectives



Question 1

In what ways can confidentiality, integrity and availability be attacked?



Question 2

What can an organization do about it: before, during and after an attack?

At the end of this class you can

- define six terms: vulnerability, threat, threat actor, cyberattack, attack vector, attack surface
- tell apart eight common types of cyberattack, and name the property each one harms
- state what a monitoring tool can observe for each attack type, and in which data source
- explain prevention, detection and response, with examples of controls
- explain why prevention alone is never sufficient
- read a short logon log, recognize two password attacks, and write the result as an incident note

Recap of Class 2: the three properties



Confidentiality

Information is read only by the people who are authorized to read it.



Integrity

Information is complete, and is changed only by authorized people in authorized ways.



Availability

Information and systems can be used when they are needed.

Together they form the **CIA** (Confidentiality, Integrity, Availability) triad. Every attack that we study today harms **at least one** of these three properties.

Why a monitoring technician studies attack types

A monitoring tool never displays the word **attack**. It displays **events**:



a failed logon



a new process



a connection to an unknown address



a sudden rise in traffic



Your work

Recognize **which attack** can produce these events.

Know **what to look for**, and **where to look**.

Competency EZ01, element 1

Criterion 1.2: differentiate the types of cyberattacks.

Criterion 1.3: illustrate the cyber defense concepts.

Rules of use: education only, authorized lab, fictional data



Education only

Attacks are described so that you can recognize, detect and defend.



Authorization first

Only systems that you own, or that the owner authorized in writing.



Authorized Lab Environment

Isolated virtual machines, designated targets, fictional data.



Never on a shared network

No capture on home, campus or work networks. Never monitor a person.



Without authorization

Applying these techniques to a system without the written authorization of its owner may be a criminal offence.

Criminal Code, sections 342.1, 342.2, 430(1.1) and 184.

Full terms: [Cyber.SoHo Legal Notice, version 2.0](#)

Each student signs Annex A of the Notice for this course before the first laboratory.



Lesson 1.3

Common types of cyberattacks

- Six terms to use with precision
- Eight types of cyberattack, and what monitoring can observe for each one
- One example with a program: recognize two password attacks in a logon log



Six terms to use with precision (1/2)



Vulnerability

A weakness in a system, in a configuration or in a human procedure that can be used to cause harm.

Examples

A missing security update. A password that is easy to guess. An untrained employee.



Threat

Any circumstance or event that can cause harm by using a vulnerability.

Examples

A criminal group looks for servers that miss one specific update.



Threat actor

The person or the group behind a threat.

Examples

A criminal group. A dishonest employee. A state organization. A person with little skill who runs tools written by others.

Six terms to use with precision (2/2)



Cyberattack

A **deliberate** action by a threat actor against the confidentiality, the integrity or the availability of information or systems.

Examples

A disk failure harms availability, but it is an accident, not an attack.



Attack vector

The **path** used to reach the target.

Examples

An e-mail message. A web form. A remote logon service. A **USB** (Universal Serial Bus) key. A stolen laptop.



Attack surface

The **total** of all the points where an attacker can try to enter.

Examples

Each new service that can be reached from the Internet enlarges it, and enlarges the list of things to monitor.



Attack type 1: Reconnaissance



What it is

- Before attacking, a threat actor collects information about the target
- Which addresses answer, which services are open, which software versions are used, which employees are named on the public website
- Technical form: **network scanning**. A program sends connection requests to many addresses and ports, and records the answers

Property harmed

C

Confidentiality

I

Integrity

A

Availability

It harms nothing directly: it is the earliest warning sign.



What monitoring can observe

- One external source tries many ports or many addresses within a few seconds

Data source: firewall log



Attack type 2: Social engineering and phishing



What it is

- **Social engineering:** manipulation of a person, so that this person helps the attacker. It targets the human, not the machine
- **Phishing:** a fraudulent message that imitates a trusted sender. It asks the reader to open an attachment, follow a link, or type a password on a false page
- **Spear phishing:** written for one specific person, with real names and real projects

Property harmed



Confidentiality



Integrity



Availability

A password is disclosed.



What monitoring can observe

- Messages from a domain name that differs by one letter from a real partner
- Later: a logon to the same account from a country where the company has no employee

Data source: mail service log, server security log



Attack type 3: Malware (1/2): five families

Malware is the short form of malicious software: any program written to harm a system or its user.



Virus

Attaches itself to a legitimate file. Runs when the user opens that file.



Spyware

Records what the user does.



Worm

Copies itself from one computer to another through the network, without any action from a user.



Keylogger

Spyware that records the keys pressed, passwords included.



Trojan

Presents itself as a useful program and performs a hidden harmful function.



One family causes the largest losses today: **ransomware**. It has its own slide.



Attack type 3: Malware (2/2): ransomware



What it is

- Encrypts the files of the victim, which makes them unreadable
- Demands a payment for the decryption key
- Many groups copy the files first, and threaten to publish them
- Named the top cybercrime threat to the critical infrastructure of Canada: [National Cyber Threat Assessment 2025-2026](#)

Property harmed



Confidentiality



Integrity



Availability

One attack harms availability and confidentiality together.



What monitoring can observe

- One account modifies hundreds of files in a few minutes
- Files receive a new, unknown extension
- Shortly before: an antivirus alert on a workstation

Data source: file audit on the server, workstation antivirus



Attack type 4: Password attacks

Objective: a valid combination of account name and password

Brute-force attack

A program tries a very large number of passwords against **one** account.

Dictionary attack

A faster variant: only the words of a prepared list of probable passwords.

Password spraying

One or two very common passwords against **many** accounts. No account reaches the limit that would lock it.

Credential stuffing

Pairs of names and passwords stolen from another website. Works because people use the same password in several places.

Property harmed



Confidentiality



Integrity



Availability

A valid password gives access to the information.



What monitoring can observe

- On a Windows server: a series of events with identifier **4625**, an account failed to log on
- Today's example and programs work on exactly this case

Data source: security event log of the server



Attack type 5: Denial of service



What it is

- **DoS** (Denial of Service) attack: more requests than the server can process, or requests built to make it fail. Legitimate users no longer receive an answer
- **DDoS** (Distributed Denial of Service) attack: the requests come from thousands of computers at the same time
- **Botnet**: computers of ordinary people, infected earlier and controlled remotely as a group

Property harmed

C

Confidentiality

I

Integrity

A**Availability**

The service can no longer answer.



What monitoring can observe

- A traffic volume far above the normal level
- A very large number of source addresses
- A response time that rises until the service stops answering

Data source: firewall log and traffic counters



Attack type 6: On-path attack



What it is

- The attacker places a device between two parties that communicate. Their traffic passes through it, where it can be read or modified
- Older name: **MITM** (Man-in-the-Middle) attack. You will hear it in today's video
- **ARP (Address Resolution Protocol) spoofing**: false address announcements, so that the other computers send their traffic to the attacker
- **Rogue access point**: a wireless access point installed without authorization, with the office network name

Property harmed



Confidentiality



Integrity



Availability

Traffic can be read and modified.



What monitoring can observe

- The same **IP** (Internet Protocol) address associated with two different hardware addresses
- An access point that uses the office name and is absent from the inventory

Data source: switch address table, wireless survey



Attack type 7: Injection



What it is

- Many web applications build a database command from the text that a user types in a form
- If the application does not verify this text, an attacker types a fragment of database command in the field
- The database executes it: tables can be read or changed
- Best-known form: **SQL (Structured Query Language) injection**

Property harmed



Confidentiality



Integrity



Availability

Tables are read that were never meant to be shown, or their content is changed.



What monitoring can observe

- Requests with database keywords or unusual punctuation in a field where a name or a number is expected
- A rise in database errors

Data source: web server log, database log



Attack type 8: Insider misuse



What it is

- The threat actor already has authorized access: an employee, a former employee whose account was not closed, a contractor
- The access is authorized; **the purpose is not**
- Examples: copying the client list before leaving for a competitor; reading the file of a relative out of curiosity
- No technical barrier is broken: prevention cannot stop it, monitoring can see it

Property harmed



Confidentiality



Integrity



Availability

Mainly confidentiality; sometimes integrity and availability.



What monitoring can observe

- Access to many files outside the normal duties of the person
- Activity at unusual hours
- Large copies toward removable media or personal cloud storage

Data source: file audit on the server



Two more terms: zero-day attack and supply-chain attack



Zero-day attack

Uses a vulnerability that the software publisher does not know yet, or has not corrected yet.

On the day of the attack, **no security update exists**.



Supply-chain attack

Reaches the target **through a supplier**.

The attacker modifies a software update, or compromises a service provider that the target trusts.



In both cases the preventive controls of the organization are intact, and the attack still succeeds.

Remember this point. It is the main argument of Lesson 1.4.



Figure 1: attack types and the property each one harms

Attack type	Confidentiality	Integrity	Availability
Reconnaissance (network scanning) preparation only: the earliest warning sign	—	—	—
Phishing (social engineering) a person is deceived into giving a password	●	○	—
Malware: ransomware files are encrypted; data is often copied first	○	○	●
Malware: spyware, keylogger, trojan information is collected in secret	●	○	—
Password attacks brute force, dictionary, spraying, credential stuffing	●	○	—
DoS (Denial of Service) and DDoS (Distributed Denial of Service) the service can no longer answer	—	—	●
On-path attack (interception) traffic passes through the attacker's device	●	●	—
SQL (Structured Query Language) injection database commands sent inside a form field	●	●	—
Insider misuse authorized access used for an unauthorized purpose	●	○	○

● main property harmed ○ often harmed as well — no direct harm

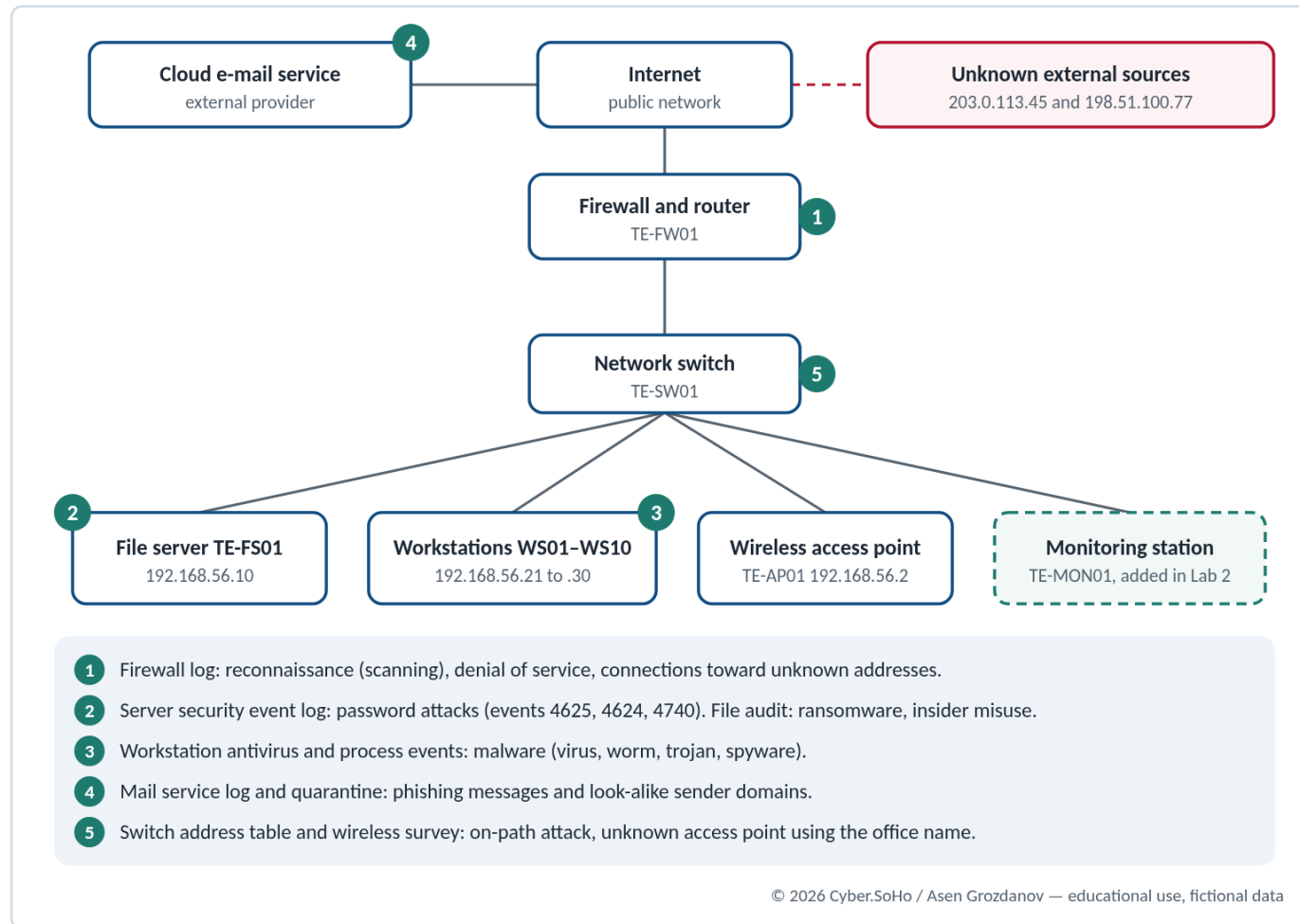
© 2026 Cyber.SoHo / Asen Grozdanov — educational use, fictional data

How to read it

- Read it line by line: one attack type per line
- **Full circle:** the main property harmed
- **Empty circle:** a property that is often harmed as well
- Reconnaissance harms nothing directly: it is the earliest warning sign
- The three columns are the **CIA** (Confidentiality, Integrity, Availability) triad of Class 2

The figure can be downloaded from the hand-out, as an image and as an editable drawing.

Figure 2: where each attack type can be observed



How to read it

- The five numbered points are the monitoring **data sources** of the office
- **1** firewall log. **2** server security log and file audit. **3** workstations
- **4** mail service. **5** network switch and wireless survey
- The monitoring station TE-MON01 is added in Lab 2
- The two red addresses are reserved for documentation: they belong to nobody

The five numbered points are the monitoring data sources of the example office. They are the first entries of the network map of Lab 1.



Table 1: attack recognition sheet (1/2)

Attack type	Main property harmed	Trace that monitoring can observe	Data source
Reconnaissance	None directly	One external source tries many ports or addresses within seconds	Firewall log
Phishing, spear phishing	Confidentiality	Look-alike domain names; later, a logon from an unusual country	Mail log, server security log
Malware families	Confidentiality, then integrity	Antivirus alert; unknown process; connection toward an unknown address	Workstations, firewall log
Ransomware	Availability, often confidentiality	One account modifies hundreds of files; new unknown extension	File audit on the server
Brute force, dictionary	Confidentiality	Series of events 4625 on one account from one source; event 4740	Server security log

The complete table, with one more column, is in the hand-out and can be downloaded as a spreadsheet file.



Table 1: attack recognition sheet (2/2)

Attack type	Main property harmed	Trace that monitoring can observe	Data source
Spraying, credential stuffing	Confidentiality	Events 4625 on many accounts from one source; then an event 4624	Server security log
Denial of service	Availability	Traffic far above the baseline; very many sources; rising response time	Firewall log, traffic counters
On-path attack	Confidentiality, integrity	One address with two hardware addresses; unknown access point	Switch table, wireless survey
Injection in a database	Confidentiality, integrity	Database keywords in a form field; rise in database errors	Web and database logs
Insider misuse	Confidentiality first	Access outside normal duties or hours; large copies of files	File audit on the server

The complete table, with one more column, is in the hand-out and can be downloaded as a spreadsheet file.



Table 3: Windows event identifiers to know

Identifier	Meaning	Why it matters for monitoring
4624	An account was successfully logged on.	Normal in large numbers. Suspicious when it follows many failures from the same source, or arrives at an unusual hour or from an unusual place.
4625	An account failed to log on.	Every password attack produces this event. Count it per account and per source.
4740	A user account was locked out.	Proof that the account lockout policy, a preventive control, reacted.
4720	A user account was created.	An attacker who obtained administrator rights often creates a new account to keep the access.
4732	A member was added to a security-enabled local group.	Watch the group Administrators: an unexpected new member is a serious sign.
1102	The audit log was cleared.	Rare in normal operation. Attackers clear logs to remove their traces.
7045	A new service was installed in the system.	Some malware installs itself as a service in order to start with the computer.
4688	A new process has been created.	Shows which program started and who started it.

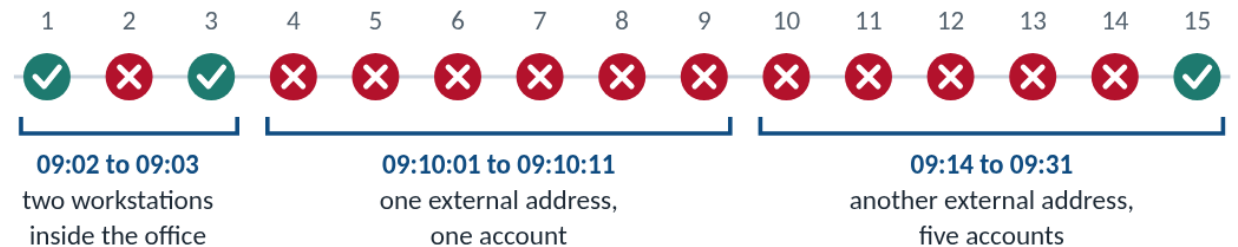
Learn first: 4624, 4625 and 4740. Official description: [Microsoft documentation of event 4625](#)

Example 1: a Friday morning on the file server

- **Trois-Érables Accounting:** fictional office of twelve people in Montréal
- File server **TE-FS01** holds the files of the clients
- Friday morning: the technician exports **15 logon records**
- Four fields: time, event identifier, account, source address
- **4624** = successful logon. **4625** = failed logon

File server TE-FS01, Friday morning: 15 logon records

Fictional office Trois-Érables Accounting. Each mark is one record of the log, in time order.



Which records are normal activity, and which belong to an attack?

Which control of the office reacted, and which did not?

failed logon, event 4625

successful logon, event 4624

© 2026 Cyber.SoHo / Asen Grozdanov — fictional data

Task

For each source address, decide: typing mistake, brute-force attack or password spraying.

Fictional data. The two external addresses belong to blocks reserved for documentation.



Example 1: the 15 logon records

Record	Time	Event	Meaning	Account	Source address
1	09:02:11	4624	successful logon	s.nguyen	192.168.56.24
2	09:03:40	4625	failed logon	m.tremblay	192.168.56.21
3	09:03:52	4624	successful logon	m.tremblay	192.168.56.21
4	09:10:01	4625	failed logon	administrator	203.0.113.45
5	09:10:03	4625	failed logon	administrator	203.0.113.45
6	09:10:05	4625	failed logon	administrator	203.0.113.45
7	09:10:07	4625	failed logon	administrator	203.0.113.45
8	09:10:09	4625	failed logon	administrator	203.0.113.45
9	09:10:11	4625	failed logon	administrator	203.0.113.45
10	09:14:20	4625	failed logon	a.gagnon	198.51.100.77
11	09:14:50	4625	failed logon	j.roy	198.51.100.77
12	09:15:20	4625	failed logon	l.cote	198.51.100.77
13	09:15:50	4625	failed logon	m.tremblay	198.51.100.77
14	09:16:20	4625	failed logon	s.nguyen	198.51.100.77
15	09:31:05	4624	successful logon	j.roy	198.51.100.77



Example 1: read the log before any program runs

Records 2 and 3

1 failure, then a success 12 seconds later. Same account, same workstation inside the office.

A person made a typing mistake

Records 4 to 9

6 failures in 10 seconds, always on the account administrator, one external address. No person types that fast: it is a program.

Brute-force attack: many passwords, one account

Records 10 to 14

5 failures from another external address, one every 30 seconds, each on a different account.

Password spraying: one password, many accounts



Record 15: fifteen minutes later, the same address logs on successfully as j.roy. The attacker has found a valid password.

Program 1: two counters and three rules

For each source address

counter 1

failed logons

counter 2

different accounts

1

4 different accounts or more



PASSWORD SPRAYING

2

otherwise, 5 failures or more



BRUTE FORCE

3

otherwise



probably a typing mistake

A successful logon **after failures** from an attacking source: **report now**

Written in Python. The program reads the 15 records one by one.

The order matters: the spraying source also has 5 failures.

The limits 4 and 5 are teaching values. Real thresholds come from the baseline of Lab 2.

Program 1: what it counted, and what it printed

Logon events on file server TE-FS01, grouped by source address

Each mark is one log record, in reading order. The program reads them from left to right.

	record	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	failed logons	different accounts
192.168.56.24 workstation WS04, inside the office		✓															0	0
192.168.56.21 workstation WS01, inside the office			✗	✓													1	1
accounts tried: m.tremblay																		
probably a typing mistake																		
203.0.113.45 unknown address on the Internet				✗	✗	✗	✗	✗	✗								6	1
accounts tried: administrator																		
198.51.100.77 unknown address on the Internet		BRUTE FORCE									✗	✗	✗	✗	✗	✓	5	5
accounts tried: a.gagnon, j.roy, l.cote, m.tremblay, s.nguyen																		
PASSWORD SPRAYING + LOGON SUCCEEDED for j.roy: report now																		
Record 15 of 15: 09:31:05 successful logon (4624) account j.roy from 198.51.100.77																		

 failed logon
  successful logon

© 2026 Cyber.SoHo / Asen Grozdanov — fictional data

```
192.168.56.21 | 1 failed | 1 account(s) | probably a typing mistake
203.0.113.45 | 6 failed | 1 account(s) | BRUTE FORCE
198.51.100.77 | 5 failed | 5 account(s) | PASSWORD SPRAYING + LOGON SUCCEEDED for
j.roy -> report now
```

The deliverable: three lines

One line for each source that failed at least once. Only the third line asks for an immediate report.

- **Lab 1:** the two rules enter the monitoring plan as suspicious behaviours.
- **Lab 2:** they become alert rules in the monitoring tool.
- **Lab 3:** a result of this kind is the evidence of the anomaly report.

Lesson 1.3: videos and practice



Simplilearn, YouTube, about 7 minutes

Cyber Security In 7 Minutes

Animated overview of the same attack types: malware, phishing, password attack, denial of service, injection.

[Open the video on YouTube](#)



Professor Messer, YouTube, about 8 minutes

Password Attacks, Security+ SY0-701, 2.4

The difference between a brute-force attack and password spraying: what you must recognize in Example 1.

[Open the video on YouTube](#)

[Same video on the author's site](#)



in the hand-out, not graded

Practice

- 5 flash cards: select a card to see its answer
- Knowledge check: 4 questions with one answer, 2 questions with several answers, each with a hint and an explanation
- Run the program yourself, step by step

The videos belong to their authors and are linked for educational purposes only. Cyber.SoHo has no affiliation with these authors or with any platform. Check every link before you open it (Legal Notice, section 14 and Annex C).



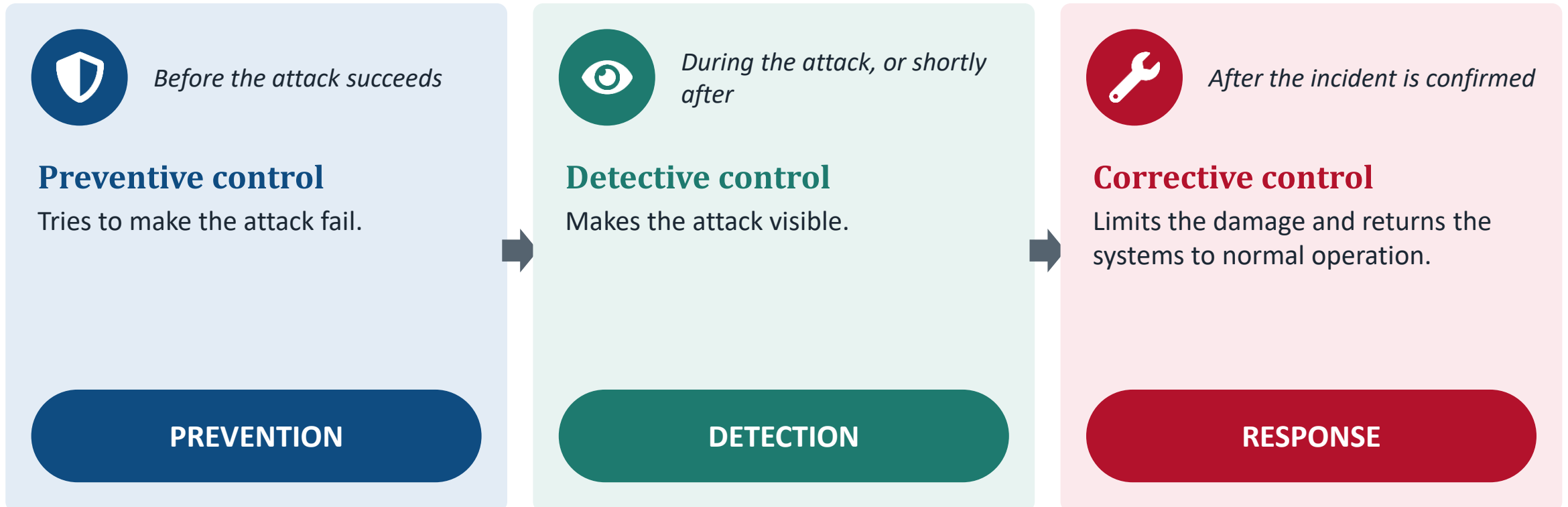
Lesson 1.4

Basic cyber defense concepts

- Three functions: prevention, detection, response
- Why prevention alone is never sufficient, and what detection needs
- One example with a program: which function reacted to which attack?

Security controls act at three moments

Cyber defense: the measures that protect information and systems against cyberattacks. One measure is a **security control**.





Prevention: seven controls you meet most often



Security updates (patches)

Correct known vulnerabilities before they are used.



Principle of least privilege

Each account has only the rights needed for the work of its owner.



MFA (Multi-Factor Authentication)

A second proof of identity: a stolen password alone is not sufficient.



Offline backups

Make recovery possible after ransomware.



Account lockout policy

Blocks an account after a fixed number of failed logons: stops brute force.



Awareness training

Teaches employees to recognize phishing.



Firewall

Allows only the network connections that a rule authorizes.

Each control addresses specific attacks. Table 2, at the end of the lesson, gives the control for each attack type.



Why prevention is never sufficient

1

Zero-day attack

It uses a vulnerability for which no update exists.

2

Human error

One employee in a hundred who types a password on a false page is enough.

3

Insider

This person already holds authorized access.

4

Limited money and staff

Some systems are always less protected than others.



A professional defender assumes that some attacks will pass the preventive controls, and prepares to see them and to act.

Seeing them is detection. It is the subject of this course.



Detection needs three things



1. Data sources

- event logs of servers and workstations
- logs of the firewall and of other network equipment
- captured network traffic; alerts of security software



2. A baseline

- a recorded description of the **normal** activity of the network
- example: the number of failed logons on a normal morning
- without it, nobody can say that an activity is abnormal. Built in Lab 2



3. Detection rules

- **threshold**: a count passes a limit within a period: 5 failed logons from one source in 10 minutes
- **signature**: the data matches the known pattern of a specific attack

Tools that apply the rules



IDS

(Intrusion Detection System)

Analyses network traffic or the activity of a computer, and **raises alerts**.



IPS

(Intrusion Prevention System)

Does the same and can also **block** the traffic: it is a preventive control as well.



SIEM

(Security Information and Event Management)

Collects the logs of many systems in **one place**, relates events from different sources, and raises alerts.



In a large organization, the people who read these alerts work in a **SOC** (Security Operations Centre).



Event, alert, incident

Event

thousands

Any recorded occurrence: a logon, a file opened.

Alert

tens

A notification produced by a rule.

Incident

a few

An event, or a group of events, that a person has analysed and confirmed as harmful.

Thousands of events produce tens of alerts, and a few alerts become incidents.



False positive, false negative and tuning



False positive

An alert raised for a **legitimate** activity.

Example: the accountant who forgot her password on a Monday morning.



False negative

A **real attack** for which no alert was raised.

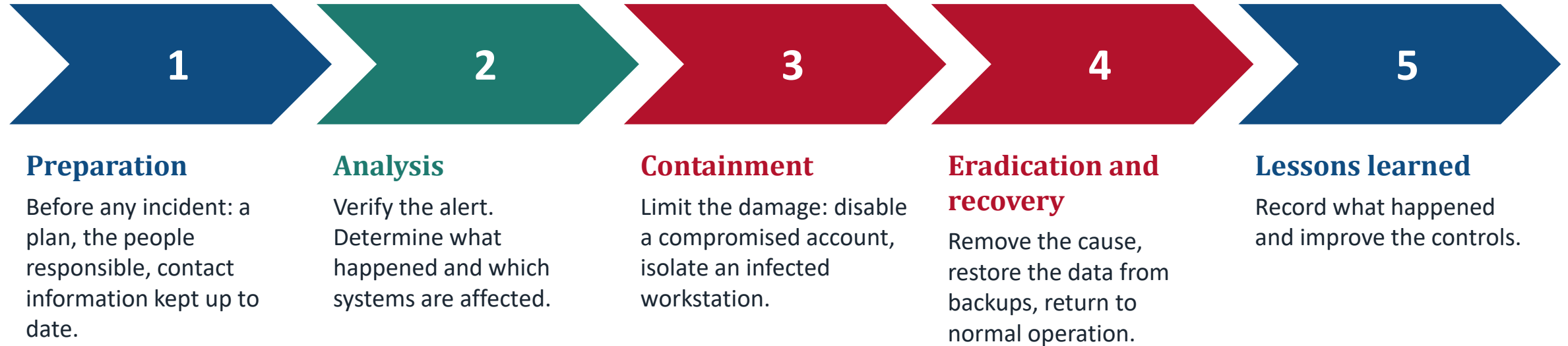
Nobody knows that it happened.

- Threshold too **low**: so many false positives that the technicians stop reading the alerts
- Threshold too **high**: attacks pass without an alert
- **Tuning**: adjusting the rules to reduce both errors. It is the subject of Topic 6

Speed of detection: **MTTD** (Mean Time to Detect), the average time between the start of an attack and its detection.



Response: five steps



Reference: [incident response guide, publication 800-61, revised in 2025](#), of **NIST** (National Institute of Standards and Technology)

Speed of response: **MTTR** (Mean Time to Respond), from the detection to the end of the recovery.

Your part in the response: under supervision

The monitoring technician



detects



analyses



documents



reports

The technician does **not** decide alone to

- block an address
- disable an account
- shut down a server on a production network

A containment action changes the system. It needs the approval of the person responsible for that system.



Your most valuable product: a clear incident note

- **what** was observed
- **when**
- on **which system**
- from **which source**
- what you **recommend**

Same rule in your laboratory work: [Cyber.SoHo Legal Notice, section 7.4](#)



In Québec: Law 25 and the confidentiality incident



Act respecting the protection of personal information in the private sector, as amended by Law 25

- **Confidentiality incident:** an incident that involves personal information
- The organization must record it in a **register**
- Risk of **serious injury**: the organization must notify the **CAI** (Commission d'accès à l'information du Québec) and the persons concerned
- The decision belongs to the person responsible for the protection of personal information, **not to the technician**

Your role

This person can decide correctly only if your incident note is **accurate** and arrives **quickly**.

Official sites

[Text of the Act \(LégisQuébec\)](#)

[Commission d'accès à l'information du Québec](#)



Defense in depth

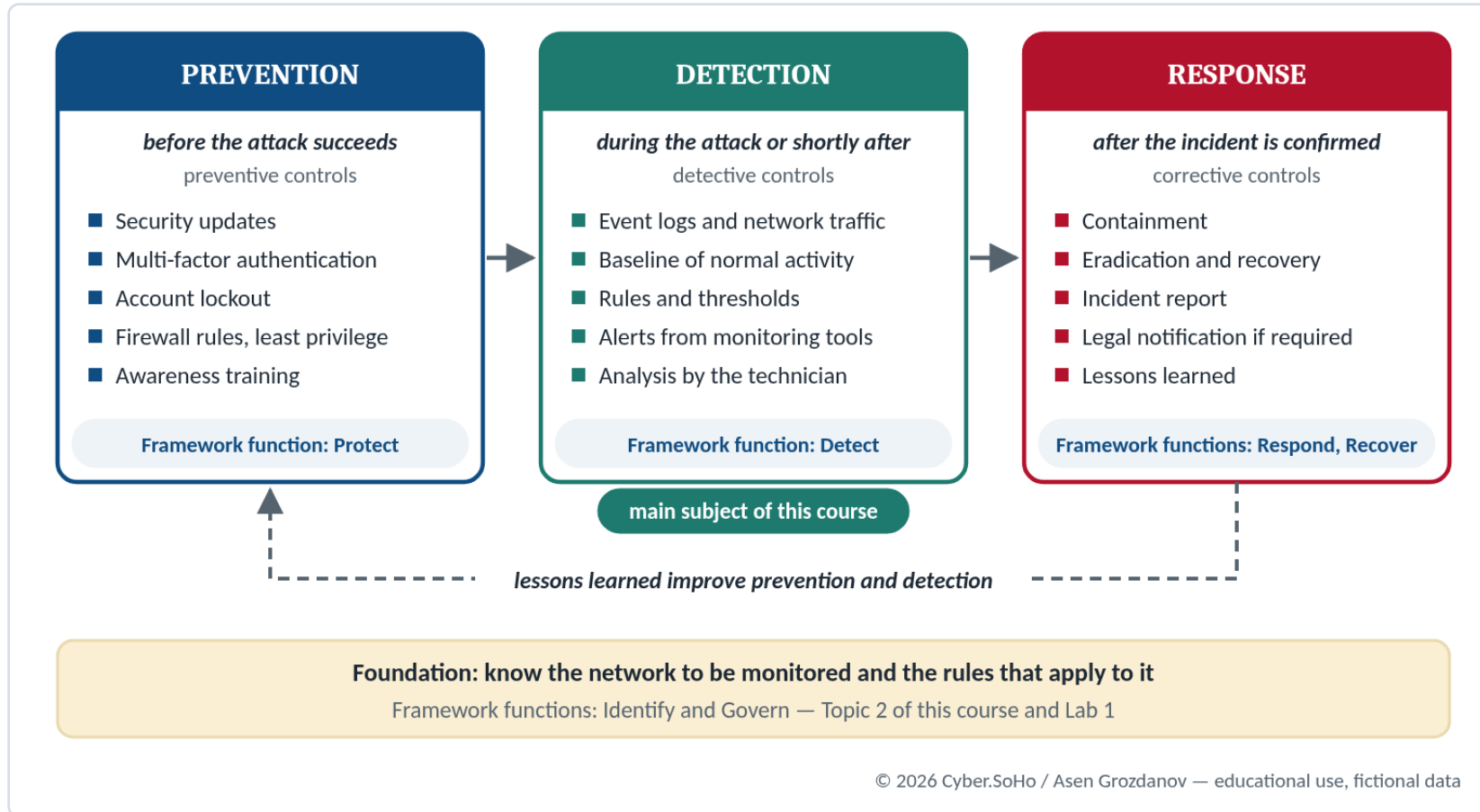
Defense in depth: several independent controls are placed one after the other, so that the failure of one control does not give access to the information.

	Brute-force attack	Password spraying
Account lockout (preventive control)	 stops it	 never reacts
Detection rule (detective control)	 sees it	 sees it

You will see these four results in Example 2, with the same fifteen records.



Figure 3: the three functions work as a cycle



How to read it

- Three functions, three moments: before, during, after
- **Detection** is the main subject of this course
- Dashed arrow: lessons learned improve prevention and detection
- Framework names: Protect, Detect, Respond and Recover
- Foundation: Govern and Identify. It is Topic 2 and Lab 1

Reference framework: [Cybersecurity Framework 2.0 of the National Institute of Standards and Technology](#)



Example 2: which defense function reacted?

Same 15 records, processed in time order, as a monitoring tool receives them.



PREVENTION

An account is locked after **5 failed logons in a row**.

Counts per **account**



DETECTION

An alert is raised at **5 failed logons from one source within 10 minutes**.

Counts per **source address**



RESPONSE

The program writes an **incident note** with recommended actions.

It **blocks nothing and changes nothing**

On a real system, every containment action needs the written approval of the owner of the system (Legal Notice, section 7.4).



Program 2 at 09:10:09: both controls react to the brute-force attack

Three defense functions acting on the same 15 events

Event 8 of 15: 09:10:09 FAILED logon (4625) account administrator from 203.0.113.45

PREVENTION: failed logons in a row, per account

The account is locked at 5 in a row.

m.tremblay



administrator



LOCKED

DETECTION: failed logons per source, last 10 minutes

Alert at 5. A box is one failure that is 10 minutes old or less now.

192.168.56.21

workstation WS01, inside the office



203.0.113.45

unknown address on the Internet



ALERT

RESPONSE: incident note written by the program. A person approves every action.

09:10:09 PREVENTION account administrator locked after 5 failed logons in a row

09:10:09 DETECTION ALERT 5 failed logons from 203.0.113.45 in 10 min, detected after 0:00:08

© 2026 Cyber.SoHo / Asen Grozdanov — fictional data

Record 8

Fifth failure on the account administrator.

- **Prevention:** the account is locked.
- **Detection:** alert in the same second, 8 seconds after the first attempt.

Both controls worked.



Program 2 at 09:16:20: only detection sees the password spraying

Three defense functions acting on the same 15 events

Event 14 of 15: 09:16:20 FAILED logon (4625) account s.nguyen from 198.51.100.77

PREVENTION: failed logons in a row, per account

The account is locked at 5 in a row.

m.tremblay		
administrator	+1	LOCKED
a.gagnon		
j.roy		
l.cote		
s.nguyen		

DETECTION: failed logons per source, last 10 minutes

Alert at 5. A box is one failure that is 10 minutes old or less now.

192.168.56.21		
workstation WS01, inside the office		
203.0.113.45	+1	ALERT
unknown address on the Internet		
198.51.100.77		ALERT
unknown address on the Internet		

RESPONSE: incident note written by the program. A person approves every action.

```
09:10:09 PREVENTION account administrator locked after 5 failed logons in a row
09:10:09 DETECTION ALERT 5 failed logons from 203.0.113.45 in 10 min, detected after 0:00:08
09:16:20 DETECTION ALERT 5 failed logons from 198.51.100.77 in 10 min, detected after 0:02:00
```

© 2026 CyberSoHo / Asen Grozdanov — fictional data

Record 14

Each account received one failure only.

- **Prevention:** no account reaches 5. The lockout does not react at all.
- **Detection:** it counts per source, not per account. Alert 2 minutes after the first attempt.



Program 2 at 09:31:05: the attacker logs on

Three defense functions acting on the same 15 events

Event 15 of 15: 09:31:05 successful logon (4624) account j.roy from 198.51.100.77

PREVENTION: failed logons in a row, per account

The account is locked at 5 in a row.

m.tremblay		
administrator	+1	LOCKED
a.gagnon		
j.roy		
l.cote		
s.nguyen		

DETECTION: failed logons per source, last 10 minutes

Alert at 5. A box is one failure that is 10 minutes old or less now.

192.168.56.21		
workstation WS01, inside the office		
203.0.113.45		ALERT
unknown address on the Internet		
198.51.100.77		ALERT
unknown address on the Internet		

RESPONSE: incident note written by the program. A person approves every action.

```
09:10:09 PREVENTION account administrator locked after 5 failed logons in a row
09:10:09 DETECTION ALERT 5 failed logons from 203.0.113.45 in 10 min, detected after 0:00:08
09:16:20 DETECTION ALERT 5 failed logons from 198.51.100.77 in 10 min, detected after 0:02:00
09:31:05 RESPONSE HIGH PRIORITY j.roy logged on from alerted source 198.51.100.77
```

© 2026 CyberSoHo / Asen Grozdanov — fictional data

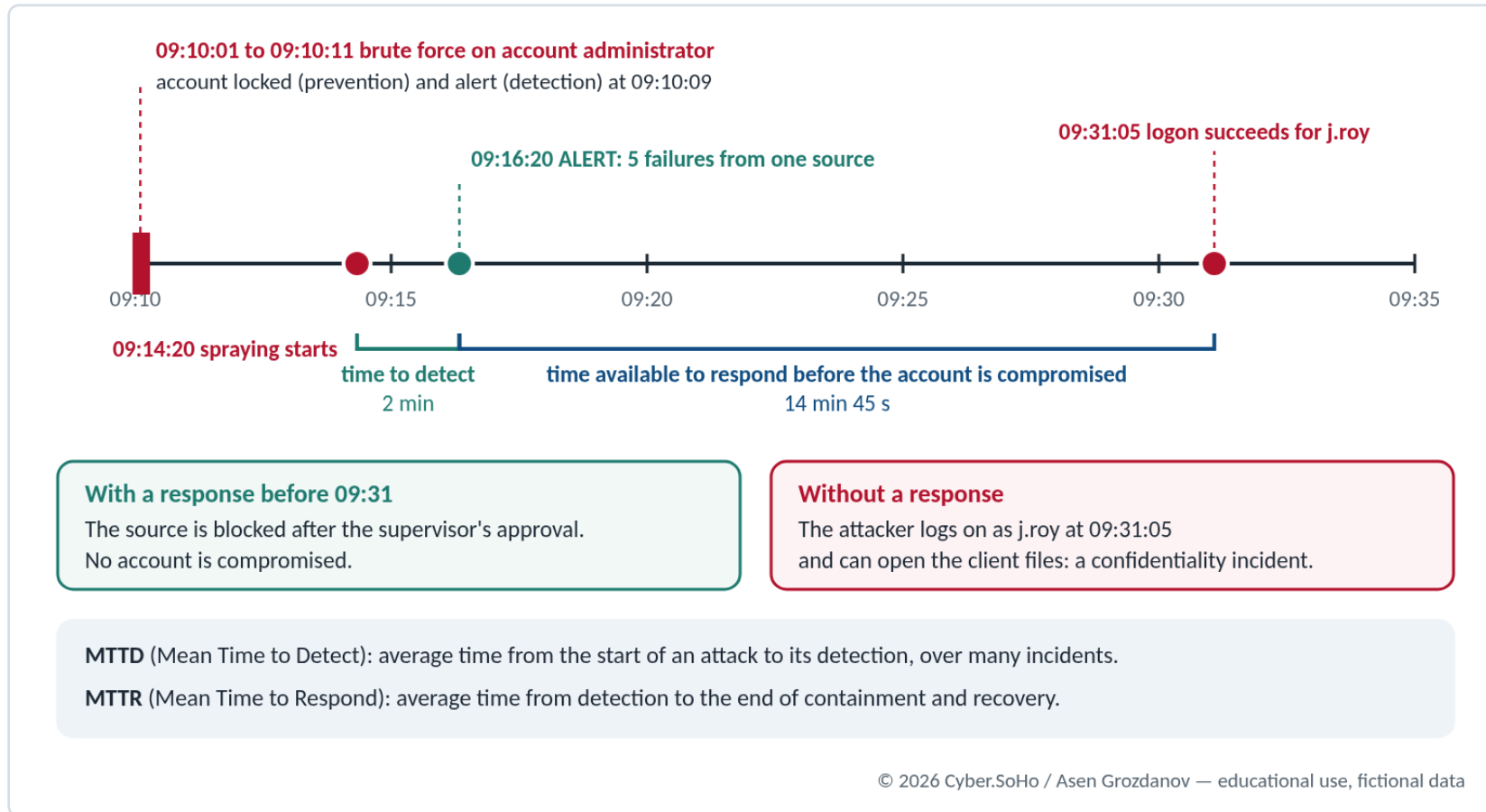
Record 15

Successful logon as j.roy from the source that is under alert.

- **Response:** the note receives a high-priority line.
- The green boxes are empty: the failures are now more than 10 minutes old. The alert remains.



Figure 4: detection gave the office 14 minutes 45 seconds



How to read it

- 09:14:20 the spraying starts.
09:16:20 alert: **time to detect, 2 minutes**
- 09:31:05 the attacker logs on as j.roy
- Between the two: **14 minutes 45 seconds** to respond
- If nobody reads the alert, detection had no effect
- **MTTD** (Mean Time to Detect) and **MTTR** (Mean Time to Respond) are averages over many incidents

If somebody reads the alert and obtains the approval to block the source during this time, no account is compromised.



Program 2: the incident note and the recommended response

INCIDENT NOTE - file server TE-FS01 - 2026-09-18 (fictional data)

09:10:09 PREVENTION account administrator locked after 5 failed logons in a row

09:10:09 DETECTION ALERT 5 failed logons from 203.0.113.45 in 10 min, detected after 0:00:08

09:16:20 DETECTION ALERT 5 failed logons from 198.51.100.77 in 10 min, detected after 0:02:00

09:31:05 RESPONSE HIGH PRIORITY j.roy logged on from alerted source 198.51.100.77

RECOMMENDED RESPONSE - to be approved by the supervisor before any change:

1. Contain: disable account j.roy, block 198.51.100.77 and 203.0.113.45 on firewall TE-FW01
2. Recover: reset the password of j.roy, review what the account opened after 09:31:05, unlock administrator
3. Report: send this note to the supervisor; the privacy officer evaluates the Law 25 obligations
4. Improve: require multi-factor authentication for remote logon and keep this alert rule active



The program **recommends** actions and changes nothing.



A person with authority **approves** every action.



This note is the format of your report in **Lab 3**.



Table 2: control map (1/2)

Attack type	Prevention	Detection: raise an alert on	Response, with approval
Reconnaissance	Close every port that is not needed	One source that tries many ports in a short time	Record the source; recommend blocking it
Phishing	Awareness training; mail filtering; multi-factor authentication	Look-alike domain names; logon from an unusual place	Reset the password; remove the message; inform the employees
Malware	Security updates; antivirus; no administrator rights for daily work	Antivirus alert; unknown process; unknown external address	Isolate the workstation; keep the evidence
Ransomware	Offline backups; least privilege on file shares	Mass modification of files; unknown file extensions	Isolate at once; restore from backups; evaluate Law 25 duties
Brute force, dictionary	Account lockout; long passwords; multi-factor authentication	5 or more failed logons on one account or from one source in 10 minutes	Verify the lockout; recommend blocking the source

Every action of the last column is a recommendation. It needs the approval of the person responsible for the system.



Table 2: control map (2/2)

Attack type	Prevention	Detection: raise an alert on	Response, with approval
Spraying, credential stuffing	Multi-factor authentication; refuse very common passwords	Failures on many accounts from one source; a success after them	Disable the account; reset its password; review what it opened
Denial of service	Protection service of the Internet provider; rate limits	Traffic far above the baseline; rising response time	Inform the provider; apply its filtering; inform the users
On-path attack	Encrypted protocols; inventory of access points	One address with two hardware addresses; unknown access point	Locate and disconnect the device; reset exposed passwords
Injection	Verification of every input; least privilege for the database account	Database keywords in form fields; rise in database errors	Inform the application owner; review which tables were read
Insider misuse	Least privilege; accounts closed on the day of departure	Access outside normal duties or hours; large copies	Preserve the logs; report to the supervisor only

Every action of the last column is a recommendation. It needs the approval of the person responsible for the system.



Lesson 1.4: videos and practice



Professor Messer, YouTube, 11 minutes 49 seconds

Security Controls, Security+ SY0-701, 1.1

Preventive, detective and corrective controls with everyday examples. The other control types of the video are not needed for Quiz 1.

[Open the video on YouTube](#)

[Same video on the author's site](#)



Professor Messer, YouTube, about 10 minutes

Incident Response, Security+ SY0-701, 4.8

The steps of incident response in order. Compare them with the five steps of this lesson.

[Open the video on YouTube](#)

[Same video on the author's site](#)



in the hand-out, not graded

Practice

- 5 flash cards: select a card to see its answer
- Knowledge check: 4 questions with one answer, 2 questions with several answers, each with a hint and an explanation
- Run the program yourself, step by step

The videos belong to their authors and are linked for educational purposes only. Cyber.SoHo has no affiliation with these authors or with any platform. Check every link before you open it (Legal Notice, section 14 and Annex C).

Lab 1 preview, and what you keep from today



Lab 1: Integrative Project, Part 1

- **When:** Class 7, Friday, September 25, online
- **Value:** 5 percent of the final grade
- **What:** map a small fictional network and write its monitoring plan
- The lab guide is distributed separately. Nothing to submit today

Only in your Authorized Lab Environment. Never map, scan or capture on a shared or real network.

Keep from Class 3	Where you use it
Table 1, recognition sheet	Lab 1: what to observe, and where. Lab 2: logs to collect
Table 2, control map	Lab 1: expected controls. Lab 2: alert rules. Lab 3: recommended actions
Table 3, event identifiers	Lab 1: events to collect. Lab 2: filters. Lab 3: evidence
Rules of Program 1	Lab 1: suspicious behaviours. Lab 2: first two alerts
Incident note of Program 2	Lab 2: test of an alert. Lab 3: format of the report



Links used in this lecture (1/2)

- [Cyber.SoHo Legal Notice and Terms of Use](#)
- [Canadian Centre for Cyber Security](#)
- [An introduction to the cyber threat environment](#)
- [Annex: the cyber threat toolbox](#)
- [National Cyber Threat Assessment 2025-2026](#)
- [Ransomware playbook](#)
- [Incident response project \(publication 800-61\)](#)
- [Cybersecurity Framework 2.0](#)
- [Commission d'accès à l'information du Québec](#)
- [Québec Act on personal information \(private sector\)](#)
- [Criminal Code of Canada](#)
- [Microsoft documentation of event 4625](#)
- [Addresses reserved for documentation \(standard 5737\)](#)
- [VirusTotal address scanner](#)

Check every link before you open it (Legal Notice, Annex C). The hand-out has a Check link button for each address. A clean result is never a guarantee.

Links used in this lecture (2/2), and additional reading

Used in this lecture

- [Google Safe Browsing site status](#)
- [Dawson College](#)
- [Python downloads](#)
- [Ministère de la Cybersécurité et du Numérique](#)
- [MITRE knowledge base of attacker techniques: **ATT&CK**](#) (Adversarial Tactics, Techniques, and Common Knowledge)
- [OWASP \(Open Worldwide Application Security Project\) Top Ten](#)
- [CIS \(Center for Internet Security\) Critical Security Controls](#)
- [Wireshark](#)
- [Bibliothèque et Archives nationales du Québec](#) (free registration)

Additional reading

- [Baseline cyber security controls \(small organizations\)](#)
- [Get Cyber Safe](#)
- [Canadian Anti-Fraud Centre](#)
- [Office of the Privacy Commissioner of Canada](#)

The four videos are on slides 29 and 51. Cyber.SoHo is independent: no affiliation with any vendor, platform or institution.



To close: three functions, one role for you



Prevention reduces the number of attacks that succeed.



Detection makes the others visible.



Response limits their effect.

You are being trained for the second function, and you need to understand the two others to do it well.

Tomorrow, Class 4: security issue versus performance issue, and **Quiz 1** (5 percent, all the material to date).

Terms of use
[Cyber.SoHo Legal Notice](#)